THREAT-EXPOSURE-TTP

공격 표면·벡터·TTPs·측면이동·CTEM

연관 기출 · 126-1-12, 138-1-10, 138-3-5, 139-1-11

한눈에 이해

취약점 개수만 세지 않고, 실제로 어디로 들어와 어떤 권한과 경로로 중요한 업무에 도달할 수 있는지 봅니다.

정의와 핵심 원리

공격 표면은 공격자가 상호 작용할 수 있는 노출 지점의 집합이고 공격 벡터는 침투·피해를 일으키는 경로·수단입니다. TTPs는 전술(목표)·기법(방법)·절차(구체적인 실행 과정)를 구분합니다. CTEM은 노출을 찾고, 우선순위를 정하고, 검증하고, 조치하는 과정을 반복하는 운영 방식입니다.

• 네트워크 스캐닝은 호스트·포트·서비스·응답 특성 등을 통해 노출을 파악합니다. 자산 발견과 취약점 진단은 다르며 스캔 결과는 방화벽·시간·네트워크 경로·인증 권한에 따라 달라집니다. 승인 범위·장치 영향·탐지 로그를 확인하고 산업 장치에는 안전한 방법을 선택합니다.

• 측면 이동은 최초 침입 뒤 다른 내부 시스템으로 접근·제어를 확장하는 행위입니다. 내부 탐색·자격 증명 획득·원격 서비스 악용·권한 확대 등이 조합되며 정상 계정으로 SSH나 RDP에 접속한 기록도 측면 이동의 흔적일 수 있습니다. 계정·단말·망의 이벤트를 연결해 경로를 분석합니다.

• CTEM은 범위 설정 → 발견 → 우선순위 결정 → 검증 → 조치의 반복 과정으로 설명할 수 있습니다. 자산 중요도·실제 도달 가능성·공격 가능성·보완 통제·업무 피해를 함께 봅니다. CVSS가 높은 항목만 나열하거나 제품 설치로 완료했다고 판단하지 않습니다.

구조·비교·판단

구분	핵심 원리	적용·한계
표면	노출 지점 전체	외부·내부·신원·공급망
벡터	공격의 진입 경로	피싱·원격 서비스 등
TTP/CTEM	공격 행동 설명 / 노출 개선 과정	관측·검증·책임자

적용 예제

인터넷 웹에서 급여 DB까지

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 외부에 노출된 웹 서버의 취약점과 서비스 계정의 과도한 권한 때문에 내부 DB에 접근할 수 있다고 가정합니다.

1. 노출과 업무 자산을 하나의 경로로 모델링합니다.
2. 웹 서버 패치와 계정 권한 축소·망 정책의 효과를 안전하게 검증합니다.
3. 접속·토큰·원격 실행 로그로 실제 이동 가능성을 평가합니다.
4. 조치 후 동일 경로를 재검증하고 새 노출을 관측합니다.

결과·해석: 단일 취약점 점수보다 중요 업무까지의 실제 경로를 기준으로 개선합니다.

전제·주의: CTEM 방법론의 전문은 열람하지 못했습니다. 다섯 단계는 학습용 개요입니다.

답안 골격과 혼동 방지

용어 구분 → TTP 구분 → 스캔 범위 → 측면 이동 경로 → CTEM의 반복 과정

- 열린 포트 모두를 취약점이라 하지 않습니다.
- TTP를 IOC 해시 목록과 동일시하지 않습니다.

내용을 가리고 회상

1. 공격 표면과 벡터의 차이는 무엇입니까?
2. 정상 계정을 쓰는 측면 이동은 어떻게 관측합니까?
3. 패치 뒤 재검증이 필요한 이유는 무엇입니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- MITRE ATT&CK TA0008 Lateral Movement - MITRE; 최종수정 2025-08-11; 확인 2026-11-05.